Guía para principiantes · Hablar con una API desde tu Mac

> Esta guía es para alguien que **empieza en tecnología**. No necesitas saber programar.
> Vamos a dar **8 pasos cortos**, y en cada uno te explico **qué hacemos y por qué**.
> Tardarás unos 20 minutos.
> Usaremos la **VulnBank API** en su versión **endurecida** (la segura). El banco es inventado: el dinero y las personas son ficticios, así que no puedes romper nada.

Primero, 4 ideas básicas

1. ¿Qué es una API? Piensa en un restaurante. Tú (el cliente) no entras a la cocina: le pides las cosas al **camarero**, y él te trae lo que pediste. Una **API** es ese camarero: un programa al que le pides datos ("¿cuánto dinero tengo?") y te responde.

2. ¿Qué es `curl`? Es una herramienta que ya viene en tu Mac para **hacerle pedidos a una API** escribiendo una línea de texto. Es como mandar una nota al camarero.

3. ¿Qué es un token? Es como la **pulsera de un concierto**: cuando demuestras quién eres (con tu usuario y contraseña) te dan una pulsera. Después, en cada pedido, enseñas la pulsera y ya no tienes que volver a dar la contraseña. La pulsera **caduca a los 15 minutos**.

4. ¿Qué es JSON? Es la forma en que la API escribe sus respuestas: una lista ordenada de **nombre: valor**, entre llaves `{ }`. Por ejemplo:

```
{ "nombre": "Laura", "saldo": 2450.75 }
```

Paso 1 · Abrir la Terminal

La **Terminal** es una ventana donde le das órdenes al Mac escribiendo.

1. Pulsa **Cmd + Espacio** (se abre el buscador).
2. Escribe `Terminal` y pulsa **Enter**.
3. Se abre una ventana con texto. Ahí vas a **pegar** los comandos de esta guía.

Cómo usar los comandos de esta guía: copia el texto del recuadro gris (Cmd + C), pégalo en la Terminal (Cmd + V) y pulsa **Enter**.

Paso 2 · Guardar la dirección de la API

La API vive en una dirección de Internet, como una página web. Como es larga, la guardamos con un nombre corto, `API`, igual que guardas un contacto en el móvil para no escribir el número cada vez.

```
API="https://yellow-ground-024d78310.6.azurestaticapps.net/api/lab"
```

No responde nada: es normal, solo la guardó.

> Si cierras la Terminal, se olvida. Al abrirla de nuevo, repite este paso.

Paso 3 · Saludar a la API

Vamos a hacer el pedido más sencillo: preguntarle qué versión es.

```
curl "$API/version"
```

Qué significa cada parte:

- `curl` → "quiero hacer un pedido".
- `"$API/version"` → a qué dirección se lo hago: la de la API + `/version`.

Respuesta:

```
{
  "lab": "VulnBank API",
  "version": "endurecida"
}
```

> Puede que al final aparezca un símbolo `%` pegado a la llave `}`. Es normal: la Terminal del Mac lo pone para avisar de que la respuesta terminó. Ignóralo.

Si ves esto, **ya hablaste con una API**. Si dice `"vulnerable"`, la versión segura no está puesta (pídele a Claude: *"coloca el laboratorio de API endurecida"*).

Paso 4 · Iniciar sesión (conseguir la pulsera)

Ahora le decimos a la API quiénes somos. Somos **Laura** y su contraseña es `Laura2026!`.

```
curl -X POST "$API/auth/login" -H "Content-Type: application/json" -d '{"username":"laur
a","password":"Laura2026!"}'
```

Qué significa cada parte:

- `-X POST` → "te **envío** datos" (hasta ahora solo **pedíamos** datos).
- `"$API/auth/login"` → la ventanilla de iniciar sesión.
- `-H "Content-Type: application/json"` → "lo que te mando está escrito en JSON".
- `-d '{...}'` → los datos que enviamos: usuario y contraseña.

Respuesta (resumida):

```
{
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOjEwMDEs...",
  "expiresIn": 900,
  "user": { "username": "laura", "fullName": "Laura Gómez", ... }
}
```

El texto largo que empieza por `eyJ` es tu **token** (tu pulsera). `"expiresIn": 900` significa que dura 900 segundos = 15 minutos.

Paso 5 · Guardar el token

Para no copiarlo en cada pedido, lo guardamos con el nombre `TOKEN`:

1. Selecciona con el ratón **solo el texto del token** (desde `eyJ` hasta antes de las comillas finales) y cópialo con **Cmd + C**.
2. Escribe esto, pegando tu token donde dice `PEGA_AQUI_TU_TOKEN`:

```
TOKEN="PEGA_AQUI_TU_TOKEN"
```

Quedará algo así (el tuyo será distinto): `TOKEN="eyJhbGciOiJIUzI1NiIs...Xyz"`

Paso 6 · Ver mis datos y mi dinero

Ahora enseñamos la pulsera en cada pedido. Se hace con `-H "X-Auth-Token: $TOKEN"`, que significa: *"esta es mi pulsera"*.

Mi perfil:

```
curl "$API/users/me" -H "X-Auth-Token: $TOKEN"
```

Verás tu nombre, email y teléfono. Fíjate en lo que **no** aparece: ni la contraseña ni el DNI. La API segura **solo enseña lo necesario**.

Mi cuenta y saldo (la cuenta de Laura es la **5001**):

```
curl "$API/accounts/5001" -H "X-Auth-Token: $TOKEN"
```

```
{ "id": 5001, "iban": "ES00 0000 0000 0000 0000 5001", "balance": 2450.75, "currency": "EU
R", ... }
```

`balance` es el saldo: **2450,75 €**.

Paso 7 · Enviar dinero a Carlos

Vamos a transferir **10 €** de la cuenta de Laura (5001) a la de Carlos (5002):

```
curl -X POST "$API/transfers" -H "X-Auth-Token: $TOKEN" -H "Content-Type: application/jso
n" -d '{"fromAccountId":5001,"toAccountId":5002,"amount":10}'
```

Los datos que enviamos (`-d`) dicen: desde la cuenta **5001**, a la **5002**, **10** euros.

Respuesta:

```
{ "ok": true, "from": { "id": 5001, "balance": 2440.75 }, "to": { "id": 5002 } }
```

`"ok": true` = la transferencia salió bien, y ahora tienes **2440,75 €**.

Paso 8 · Intentar hacer trampa (y ver cómo la API se defiende)

Una API segura **comprueba todo** antes de obedecer. Probemos tres trampas:

Trampa 1 · Mirar la cuenta de otra persona. Pedimos la cuenta de Carlos (5002) con la pulsera de Laura:

```
curl "$API/accounts/5002" -H "X-Auth-Token: $TOKEN"
```

```
{ "error": "Cuenta no encontrada" }
```

Por qué: la API revisa que la cuenta sea **tuya**. Como no lo es, responde como si no existiera (así ni siquiera revela que existe).

Trampa 2 · Enviar dinero "negativo". Si mandas **−1000 €** a Carlos, en un sistema mal hecho eso le **quitaría** 1000 € a él y te los daría a ti:

```
curl -X POST "$API/transfers" -H "X-Auth-Token: $TOKEN" -H "Content-Type: application/jso
n" -d '{"fromAccountId":5001,"toAccountId":5002,"amount":-1000}'
```

```
{ "error": "amount debe ser un número positivo con máximo 2 decimales" }
```

Por qué: la API comprueba que el importe sea positivo y que tengas saldo.

Trampa 3 · Pedir datos sin pulsera. Quitamos la parte del token:

```
curl "$API/users/me"
```

```
{ "error": "Falta un token válido (cabecera X-Auth-Token)" }
```

Por qué: sin identificarte, la API no te da información privada.

> **Esta es la idea principal de la seguridad en APIs:** la API **nunca debe confiar** en lo que le pide el cliente. Debe comprobar **quién eres**, **si lo que pides es tuyo** y **si los datos tienen sentido**. En la versión vulnerable del laboratorio, estas tres trampas **sí funcionan**.

Para terminar · Dejar todo como al principio

Esto devuelve los saldos a sus valores iniciales, para la siguiente persona:

```
curl -X POST "$API/reset"
```

```
{ "ok": true, "message": "Datos del laboratorio restaurados" }
```

Si algo sale mal

Ves esto	Qué pasa	Qué hacer
`Falta un token válido`	La pulsera caducó (15 min) o no la guardaste bien.	Repite los pasos 4 y 5.
`Credenciales inválidas`	Usuario o contraseña mal escritos.	Copia el comando del paso 4 tal cual.
`Demasiados intentos`	Fallaste la contraseña 5 veces: la API te bloquea (¡es una defensa!).	Ejecuta el comando de "Para terminar" y vuelve al paso 4.
`zsh: no matches found`	La dirección quedó sin comillas.	Copia el comando completo, con sus comillas.
`Could not resolve host`	No hay Internet o el paso 2 no se hizo.	Revisa la conexión y repite el paso 2.
No pasa nada al pulsar Enter	Faltó cerrar unas comillas.	Pulsa **Ctrl + C** y vuelve a pegar el comando.

Mini-diccionario

Palabra	Qué significa
API	Programa que recibe pedidos y devuelve datos (el camarero).
curl	Herramienta del Mac para hacerle pedidos a una API.
GET	Pedir datos (lo que hace `curl` si no dices nada).
POST	Enviar datos (`-X POST`), por ejemplo para iniciar sesión o transferir.
Token	Tu "pulsera" para demostrar quién eres en cada pedido. Caduca.
JSON	Formato de las respuestas: `{ "nombre": valor }` .
Endpoint	Cada "ventanilla" de la API, como `/version` o `/accounts/5001` .
Cabecera (`-H`)	Información extra que acompaña al pedido, como la pulsera.